GDPR Audit Pack — Part 4

Phase 4 & 5: Peer Review Rubric + Debrief & Divergence Analysis **Audit Partner Swap Exercise**

Reviewer: Pedro | **Memo Author:** Mona | **Date Reviewed:** March 26, 2026

📋 Peer Review Rubric (Reviewer as Client)

Criterion	Score (1–3)	Reviewer Comment
Clear bottom-line recommendation	3 / 3	"GO WITH CONDITIONS" is clear, bold, and followed by a concise one-sentence reason. Excellent executive summary.
Lawful basis selection is justified	3 / 3	Legitimate interests used throughout. The UK GDPR note adds nuance about ICO scrutiny—shows depth of analysis.
Top actions are specific and sequenced	3 / 3	Three actions clearly sequenced: (1) DPA/SCCs/TIA, (2) DPIA, (3) Redaction + Privacy Notice. Each includes concrete deliverables.
Residual risks are named honestly	3 / 3	Model memorization, regulatory divergence, human oversight erosion—all candidly disclosed with practical mitigations.
Law stacking is addressed (AI Act / ePrivacy)	2 / 3	AI Act and ePrivacy are covered in Section C (outside memo). The memo itself could briefly restate AI Act tier for completeness. Minor gap.

🗣️ Client Feedback (Peer Acting as Client)

"I accept the recommendation. The three actions are exceptionally well-sequenced, and the UK GDPR note adds valuable foresight. One concern: the AI Act classification (Limited Risk) appears in Section C but not in the memo body—executives may miss it. I'd ask for a redesign to include a one-line AI Act reference in the memo itself for completeness. Also, the TIA requirement is strong, but consider adding that we should evaluate EU-based LLM alternatives if the TIA reveals unacceptable risks. Otherwise, this is a superb audit—thorough, practical, and risk-aware."

✅ **Recommendation accepted with minor clarification. Consultant will add AI Act reference to memo body and EU-alternative consideration.**

🔄 Debrief: Divergence Analysis (Partner Comparison)

Agreements: Both Pedro and Mona agreed that **legitimate interests** is the appropriate lawful basis, that a **DPIA is mandatory**, and that the OpenAI transfer requires SCCs + DPA. Both agreed on the three core actions and their sequence.

Divergence Point 1 — UK GDPR Consideration:
Pedro's memo: Did not address UK GDPR separately.
Mona's memo: Included a dedicated UK GDPR note with IDTA/UK Addendum requirements and ICO stance on legitimate interests.
Resolution: Mona's inclusion is stronger and more comprehensive. If CloudSaaS serves UK data subjects, this is essential. We will adopt Mona's UK GDPR note as a standard addition to all client memos where EU/UK data subjects are present.

Divergence Point 2 — Human Oversight Safeguard Detail:
Pedro's memo: Mentions right to be forgotten complexity but focuses less on agent override monitoring.
Mona's memo: Explicitly calls out "human oversight erosion" as a residual risk and requires override rate monitoring and random audits.
Resolution: Mona's approach provides more operational specificity. We will incorporate override rate monitoring into the implementation plan.

Divergence Point 3 — AI Act Transparency Location:
Pedro's memo: Includes AI Act classification within the memo body under "AI Act & ePrivacy Stacking" section.
Mona's memo: Places AI Act analysis in Section C (law stacking) but not in the memo body.
Resolution: Pedro's placement is more client-friendly—executives should see AI Act

classification directly in the recommendation memo. We will add a brief AI Act reference to the memo body in final version.

> 📌 **Final Agreed Position (Post-Debrief):**
> • Maintain “GO WITH CONDITIONS” bottom line.
> • Incorporate UK GDPR note into all client-facing memos (Mona's strength).
> • Add AI Act classification (Limited Risk) to memo body for executive visibility (Pedro's strength).
> • Include override rate monitoring as operational control (Mona's strength).
> • Add EU-alternative consideration to TIA requirement.